

EXECUTIVE BRIEF

Trusted context. Clear next steps.

One longitudinal care note that turns fragmented clinical, staff and AI entries into a source-linked consult glance - while keeping authorization, revision history and clinician judgment explicit.

6.38 ms

WARM SSR P95 / TARGET <= 300 MS

11 + 1

DOMAIN TESTS + RENDERED-SHELL TEST

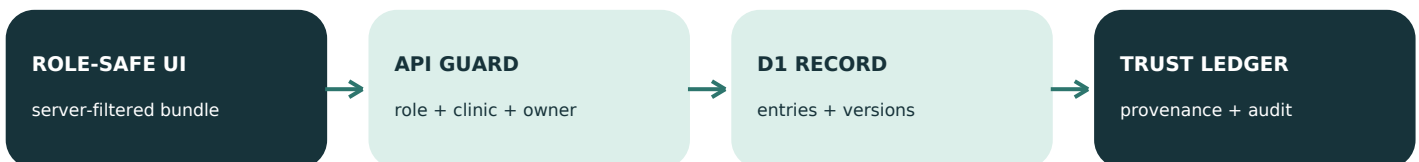
4 / 4

PRIORITY CARDS RESOLVE TO A SOURCE

Highest-value trust loop



Runtime architecture

**AI BOUNDARY**

Voice/text intake -> local identifier redaction -> fail-closed model gateway -> separate pending-review AI entry.

No external model call runs in this prototype. AI never silently overwrites clinician-authored content.

72-hour product decision

Build one complete, inspectable trust loop before adding real ambient capture or broad EHR scope. Every record and identity in the demo is synthetic.

SERVER-ENFORCED

Roles, revisions and accountable AI

UI visibility is never authorization. Each protected request derives the actor from an HttpOnly session and rechecks role, clinic and section ownership.

RBAC matrix

ACTOR	READ	WRITE
Patient	Patient-visible instructions only	No internal notes or comments
Staff	Same-clinic staff/patient/shared AI	Staff notes + comments
Clinician	All same-clinic entries + AI context	Clinician notes + AI review
Admin	Same-clinic oversight + audit metadata	No clinical/staff overwrite

Three distinct accountability records

REVISION

Recoverable content snapshot

full content + version + editor

PROVENANCE

How an output came to exist

source entry + version + quote

AUDIT EVENT

Who acted and with what outcome

actor + action + versions; no raw note

Safe edit and revert sequence

- 1

Client sends content + expectedVersion
- 2

Server rechecks role / clinic / section
- 3

Atomic update only if version matches
- 4

New snapshot + append-only audit metadata

SAFETY BOUNDARY

Regex redaction is a prototype control, not certified de-identification. Production requires stronger entity detection, fail-closed review, vendor retention controls and legal/security validation before real patient data.

MEASURED AND EXPLICIT

Evidence, performance and next steps

3.44 ms

WARM SSR P50

6.38 ms

WARM SSR P95

10.58 ms

WARM SSR MAXIMUM

5 warm-ups + 30 measured sequential requests against the built Worker. This is shell time, not an internet or clinical SLA.

Automated validation

- Clinic and role scope; patient internal-note boundary
- Immutable revisions; revert creates a new version
- Exact highlight source, source version and quoted span
- Stale same-section write returns deterministic conflict
- Separate role-owned sections do not overwrite each other
- Clinician feedback changes bounded importance weights
- Identifiers are removed before the model boundary

72-hour scope: now vs. next

BUILT NOW

- Glance + exact source jumps
- Server RBAC + comments
- Versions + real revert + conflicts
- Feedback learning + audit
- Pre-model redaction boundary

NEXT VALIDATION GATE

- Clinic SSO and membership claims
- Clinician study on synthetic cases
- Consented multilingual ambient capture
- Stronger entity detection + review
- Security/legal review before real data

Evidence used to shape the build

Singapore MOH - patient-data AI security requirements (4 Aug 2026)

OWASP A01 - server-side, deny-by-default access control

HL7 FHIR R5 - Provenance and AuditEvent separation

HHS - formal de-identification pathways and residual risk

NIST AI RMF 1.0 - transparent, monitored AI risk management

JMIR 2026 - ambient workflow effects and AI-scribe quality risks

Full URLs and claim-level notes: [README.md](#) and [research/claim-source-ledger.md](#)